Compte rendu – TP2

Gestion avancée des utilisateurs et des groupes – permissions, ACL et sudoers – projet « Hélios »
Administration d'un Linux Server – Bachelor Informatique 2e année (BTC2), IPSSI Lille

Étudiant	Bilal Chaybouti
Date	3 novembre 2026
Environnement	VirtualBox – Rocky Linux 9.8 Minimal – `srv-core` (192.168.56.10)
Résultat	Missions 1 à 4 et bonus réalisées – livrables fournis

Sommaire et bilan

Livrable / objectif	Preuve	Statut
chage -l julien, getent group transport	§1.2	✔
faillock --user nadia avant/après reset	§1.3	✔
Refus d'un mot de passe faible	§1.3	✔
Répertoires setgid / sticky, héritage et refus de suppression	§2.1	✔
Tableau umask prédit / observé	§2.2	✔ **(5/5)**
Inventaire setuid, faux setuid, helios-lastlog	§2.3	✔
ACL nominatives et par défaut, lecture par l'auditeur	§3.1, §3.2	✔
getfacl avant/après chmod g-w (#effective)	§3.3	✔
Sauvegarde / restauration des ACL	§3.4, configs/	✔
sudo -l -U julien, visudo -c, sudoreplay -l	§4.1, §4.2	✔
Évasion de shell via sudo vim, puis correction sudoedit	§4.3	✔
Bonus : audit, 5 constats et remédiations	§5	✔

Modèle de droits mis en place

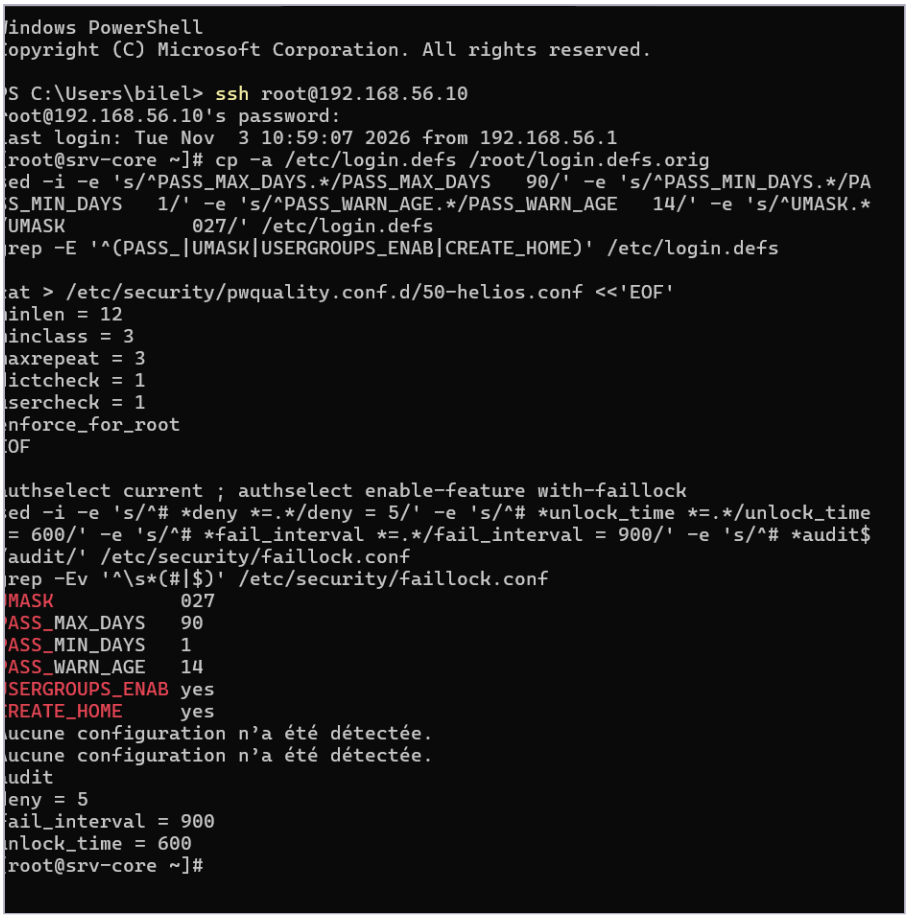
Compte	UID	Groupe principal	Groupes secondaires	Rôle et droits
julien	5100	transport	helios-ops	Chef d'équipe, administrateur du groupe transport, sudo limité au collecteur
nadia	5101	transport	–	Exploitante, sudoedit sur les fichiers de transport
tarek	5102	telemetry	transport	Analyste télémétrie
audit-ext	5103	telemetry	–	Auditeur : lecture seule par ACL, compte expirant le 24/11/2026

Mission 1 – Comptes, groupes et authentification

1.1 Politique définie avant la création des comptes

Un compte hérite de la politique en vigueur au moment de sa création : elle est donc posée en premier.

- **/etc/login.defs** : expiration à 90 jours, 1 jour minimum entre deux changements, alerte 14 jours avant, `UMASK 027` ;
- **pam_pwquality** (`50-helios.conf`) : 12 caractères minimum, 3 classes de caractères, pas plus de 3 caractères identiques consécutifs, contrôle du dictionnaire et du nom d'utilisateur, appliqué aussi à root ;
- **pam_faillock** : 5 échecs en 15 min (`fail_interval=900`) verrouillent le compte 10 min (`unlock_time=600`), avec journalisation (`audit`).



login.defs et faillock.conf configurés

> **Écart avec l'énoncé :** `authselect current` répondait « Aucune configuration n'a été détectée » : aucun profil n'était sélectionné, donc `enable-feature with-faillock` était sans effet. Le profil a été sélectionné explicitement, avec une sauvegarde des fichiers PAM : `authselect select sssd with-faillock --force --backup=avant-tp2`

```
unlock_time = 600
[root@srv-core ~]# authselect select sssd with-faillock --force --backup=ava
nt-tp2
authselect current
grep faillock /etc/pam.d/system-auth
Sauvegarde stockée à /var/lib/authselect/backups/avant-tp2
Le profil « sssd » a été sélectionné.
Les mappages nsswitch suivants ont été remplacés par le profil :
- passwd
- group
- netgroup
- automount
- services

Make sure that SSSD service is configured and enabled. See SSSD documentatio
n for more information.

ID du Profil : sssd
Fonctionnalités activées :
- with-faillock
auth        required                                    pam_faillock.so pre
auth silent
auth        required                                    pam_faillock.so aut
hfail
account     required                                    pam_faillock.so
[root@srv-core ~]#
```

Profil sssd + with-faillock : pam_faillock.so présent dans system-auth

1.2 Squelette, groupes et comptes

`/etc/skel/.bashrc` reçoit les réglages communs (éditeur, historique horodaté), sans umask, pour ne pas écraser le umask par groupe de la mission 2. Trois groupes sont créés (transport 5000, telemetry 5001, helios-ops 5002), puis quatre comptes avec mot de passe initial et `chage -M 90 -m 1 -W 14 -I 7`. L'auditeur reçoit une date d'expiration de compte à +21 jours (`-e`).

```
[root@srv-core ~]# cat >> /etc/skel/.bashrc <<'EOF'
# socle Helios
export EDITOR=vim HISTSIZE=5000 HISTTIMEFORMAT='%F %T '
EOF

groupadd -g 5000 transport
groupadd -g 5001 telemetry
groupadd -g 5002 helios-ops

useradd -u 5100 -g transport -G helios-ops -c "Julien Marty - chef equipe tr
ansport" -m julien
useradd -u 5101 -g transport -c "Nadia Belkacem - exploitante" -m nadia
useradd -u 5102 -g telemetry -G transport -c "Tarek Oualid - analyste teleme
trie" -m tarek
useradd -u 5103 -g telemetry -c "Auditeur externe - mandat Q4" -m -e "$(date
 -d '+21 days' +%F)" -s /bin/bash audit-ext

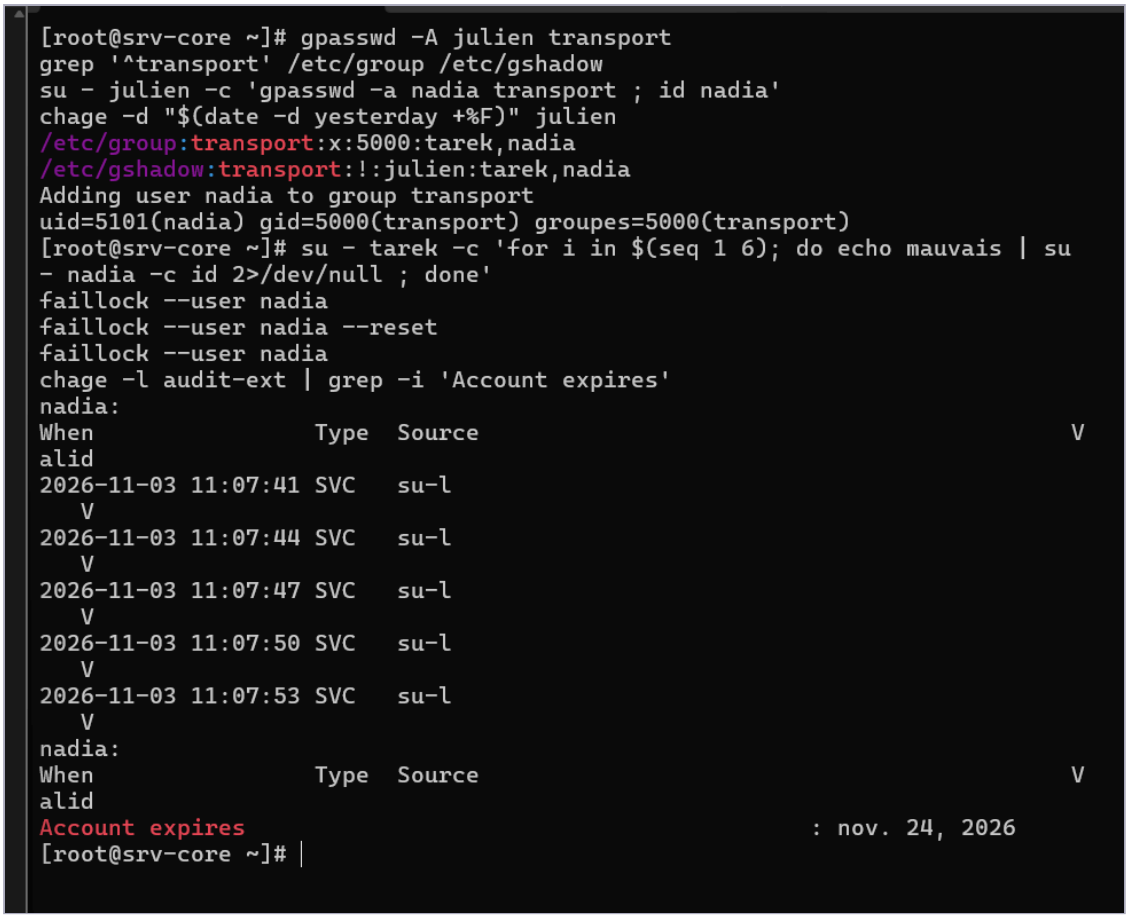
for u in julien nadia tarek audit-ext ; do
  echo "${u}:Helios-TP2-2026" | chpasswd
  chage -M 90 -m 1 -W 14 -I 7 "$u"
done
chage -l julien
getent passwd julien nadia tarek audit-ext ; getent group transport telemetr
y helios-ops
Last password change                                    : nov. 03, 2026
Password expires                                        : févr. 01, 2027
Password inactive                                       : févr. 08, 2027
Account expires                                         : never
Minimum number of days between password change          : 1
Maximum number of days between password change          : 90
Number of days of warning before password expires       : 14
julien:x:5100:5000:Julien Marty - chef equipe transport:/home/julien:/bin/ba
sh
nadia:x:5101:5000:Nadia Belkacem - exploitante:/home/nadia:/bin/bash
tarek:x:5102:5001:Tarek Oualid - analyste telemetrie:/home/tarek:/bin/bash
audit-ext:x:5103:5001:Auditeur externe - mandat Q4:/home/audit-ext:/bin/bash
transport:x:5000:tarek
telemetry:x:5001:
helios-ops:x:5002:julien
[root@srv-core ~]#
```

chage -l julien, getent passwd et getent group

`getent group transport` n'affiche que `tarek` : `/etc/group` ne liste que les membres **secondaires**. Pour julien et nadia, transport est le groupe principal, indiqué par le GID 5000 dans `/etc/passwd`.

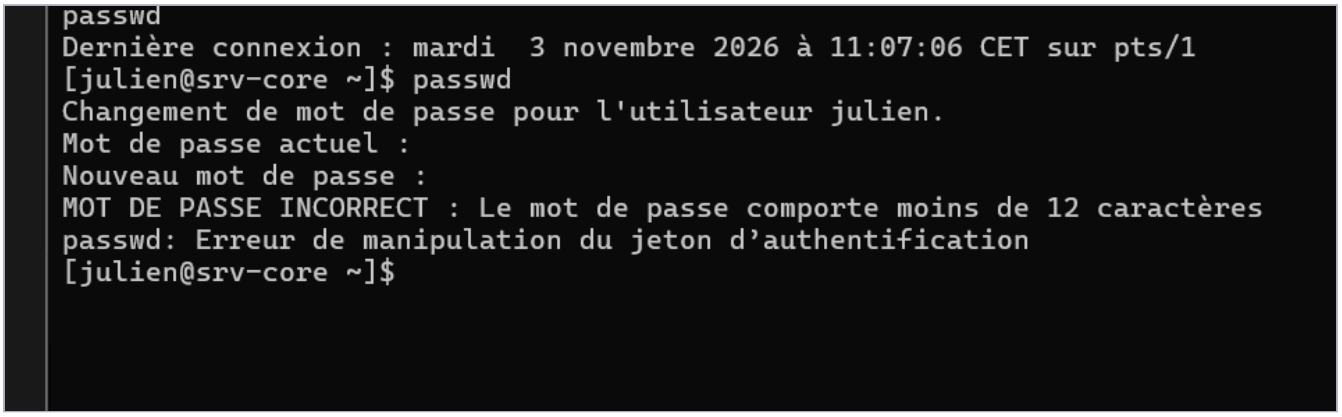
1.3 Administrateur de groupe, mot de passe faible, verrouillage

`gpasswd -A julien transport` délègue la gestion des membres à julien, qui ajoute lui-même nadia sans être root (visible dans `/etc/gshadow` : `transport:!:julien:tarek,nadia`).



gshadow, faillock de nadia avant et après reset, expiration de l'auditeur

Sur 6 tentatives échouées, faillock n'en enregistre que **5** : au 5e échec, le compte est verrouillé et la 6e tentative est rejetée sans évaluation (`deny = 5`). Après `faillock --reset`, la liste est vide. Le compte audit-ext expire le **24 nov. 2026**.



« Le mot de passe comporte moins de 12 caractères » : refus par pam_pwquality

Le changement a été rendu possible par `chage -d hier julien`, car `PASS_MIN_DAYS=1` interdit sinon tout changement le jour même.

Mission 2 – Bits spéciaux et umask

2.1 setgid sur le projet, sticky bit sur le dépôt

```
[root@srv-core ~]# install -d -m 0755 /srv/helios/projets
install -d -m 2770 -o julien -g transport /srv/helios/projets/transport
install -d -m 0770 -o julien -g transport /srv/helios/projets/temoin
ls -ld /srv/helios/projets/transport /srv/helios/projets/temoin
su - tarek -c 'touch /srv/helios/projets/transport/tournee-tarek.csv /srv/he
lios/projets/temoin/y ; ls -l /srv/helios/projets/transport/tournee-tarek.cs
v /srv/helios/projets/temoin/y'
su - nadia -c 'touch /srv/helios/projets/transport/tournee-nadia.csv'
drwxrwx---. 2 julien transport 6  3 nov.  11:10 /srv/helios/projets/temoin
drwxrws---. 2 julien transport 6  3 nov.  11:10 /srv/helios/projets/transpor
t
-rw-r-----. 1 tarek telemetry 0  3 nov.  11:10 /srv/helios/projets/temoin/y
-rw-r-----. 1 tarek transport 0  3 nov.  11:10 /srv/helios/projets/transport
/tournee-tarek.csv
[root@srv-core ~]# install -d -m 1777 /srv/helios/depot ; ls -ld /srv/helios
/depot
su - nadia -c 'echo n > /srv/helios/depot/fichier-nadia'
su - tarek -c 'rm -f /srv/helios/depot/fichier-nadia' ; echo "rc attendu !=
0 : $?"
chmod 0777 /srv/helios/depot
su - tarek -c 'rm -f /srv/helios/depot/fichier-nadia' ; echo "rc attendu 0 :
 $?"
chmod 1777 /srv/helios/depot
drwxrwxrwt. 2 root root 6  3 nov.  11:10 /srv/helios/depot
rm: impossible de supprimer '/srv/helios/depot/fichier-nadia': Opération non
 permise
rc attendu != 0 : 1
rc attendu 0 : 0
[root@srv-core ~]#
```

Héritage du groupe par setgid, refus de suppression par le sticky bit

Répertoire	Mode	Effet observé
/srv/helios/projets/transport	`drwxrws---` (2770)	Le fichier créé par tarek appartient au groupe **transport** (groupe du répertoire)
/srv/helios/projets/temoin	`drwxrwx---` (0770)	Le fichier créé par tarek appartient à **telemetry** (son groupe principal)
/srv/helios/depot	`drwxrwxrwt` (1777)	tarek ne peut pas supprimer le fichier de nadia (rc=1) ; sans sticky (0777), il le peut (rc=0)

La preuve se fait avec tarek, car le groupe principal de nadia est déjà transport : sur elle, le setgid ne changerait rien de visible.

2.2 umask : prédiction puis mesure

Un fichier est créé au maximum en 666 et un répertoire en 777 ; l'umask retire les bits correspondants.

Cas	umask	Prédit	Observé
/tmp/u1 (fichier)	027	-rw-r----- (640)	**-rw-r-----**

/tmp/d1 (répertoire)	027	drwxr-x--- (750)	**drwxr-x---**
/tmp/u2	002	-rw-rw-r-- (664)	**-rw-rw-r--**
/tmp/d2	002	drwxrwxr-x (775)	**drwxrwxr-x**
/tmp/u3	077	-rw------- (600)	**-rw-------**

```
[root@srv-core ~]# su - nadia -c 'umask ; touch /tmp/u1 ; mkdir /tmp/d1 ; ls
 -ld /tmp/u1 /tmp/d1'
su - nadia -c 'umask 002 ; touch /tmp/u2 ; mkdir /tmp/d2 ; ls -ld /tmp/u2 /t
mp/d2'
su - nadia -c 'umask 077 ; touch /tmp/u3 ; ls -l /tmp/u3'
0027
drwxr-x---. 2 nadia transport 6  3 nov.  11:11 /tmp/d1
-rw-r-----. 1 nadia transport 0  3 nov.  11:11 /tmp/u1
drwxrwxr-x. 2 nadia transport 6  3 nov.  11:11 /tmp/d2
-rw-rw-r--. 1 nadia transport 0  3 nov.  11:11 /tmp/u2
-rw-------. 1 nadia transport 0  3 nov.  11:11 /tmp/u3
[root@srv-core ~]#
```

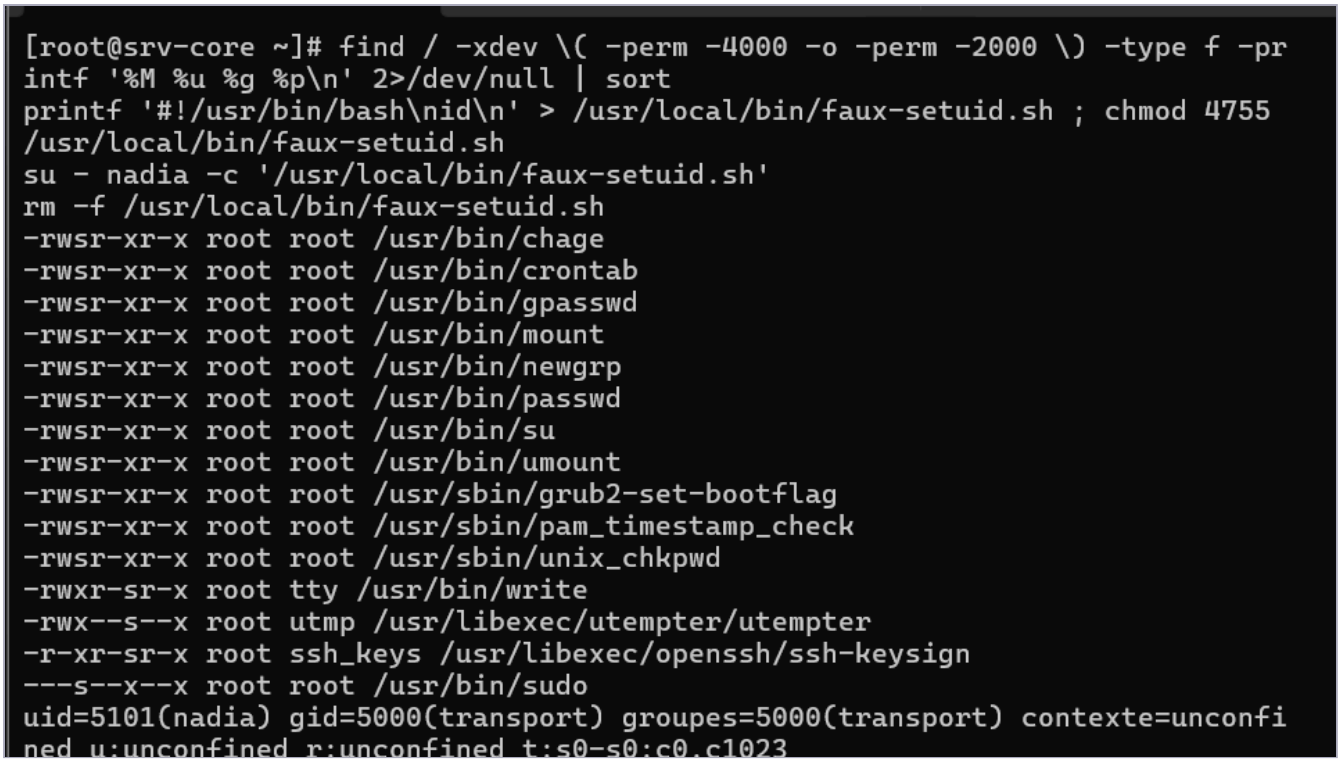
Mesures : les 5 cas correspondent aux prédictions

umask par groupe : `/etc/profile.d/helios-umask.sh` applique 002 aux membres de transport (travail collaboratif avec le setgid) et 027 aux autres. Ce réglage est volontairement placé hors de `~/.bashrc`, lu après `/etc/profile.d`, qui l'écraserait.

```
[root@srv-core ~]# cat > /etc/profile.d/helios-umask.sh <<'EOF'
# umask 002 pour les membres de transport (travail collaboratif setgid), 027
 sinon.
if id -nG | tr ' ' '\n' | grep -qx transport ; then umask 002 ; else umask 0
27 ; fi
EOF
chmod 0644 /etc/profile.d/helios-umask.sh
su - nadia -c 'umask ; touch /srv/helios/projets/transport/partage.txt ; ls
-l /srv/helios/projets/transport/partage.txt'
su - audit-ext -c 'umask'
0002
-rw-rw-r--. 1 nadia transport 0  3 nov.  11:12 /srv/helios/projets/transport
/partage.txt
0027
[root@srv-core ~]#
```

nadia : 0002 et partage.txt en -rw-rw-r-- groupe transport ; audit-ext : 0027

2.3 setuid : inventaire, faux setuid, usage légitime



Inventaire setuid/setgid (15 binaires système) et faux setuid : uid reste nadia

Le noyau ignore le bit setuid sur les scripts interprétés : sinon, on pourrait détourner l'interpréteur (variables d'environnement, condition de course sur le fichier) pour exécuter du code en root. `id` affiche donc toujours `uid=5101(nadia)`.

Cas légitime : `helios-lastlog`, binaire C compilé (`gcc` installé au préalable, absent de l'image Minimal), installé `root:telemetry` en **2755**. Le bit setgid donne l'egid telemetry, qui suffit pour lire `app.log` (0640 root:telemetry), sans jamais accorder l'uid root. Le programme fige son environnement (`PATH`, `IFS`) et le chemin du fichier lu, pour empêcher toute injection.

```
ant.
 * Environnement et chemin figes pour eviter toute injection via PATH/IFS. *
/
#include <unistd.h>
#include <stdio.h>

int main(void)
{
    char *env[] = { "PATH=/usr/bin:/bin", "IFS= \t\n", NULL };
    execle("/usr/bin/tail", "tail", "-n", "10",
           "/var/log/helios/app.log", (char *)NULL, env);
    perror("execle");
    return 1;
}
EOF
gcc -O2 -Wall -Wextra -o /usr/local/bin/helios-lastlog /root/helios-lastlog.
c
chown root:telemetry /usr/local/bin/helios-lastlog
chmod 2755 /usr/local/bin/helios-lastlog ; ls -l /usr/local/bin/helios-lastl
og

su - julien -c 'tail -n 3 /var/log/helios/app.log' ; echo "rc attendu != 0 :
 $?"
su - julien -c '/usr/local/bin/helios-lastlog' ; echo "rc attendu 0 : $?"
-rwxr-sr-x. 1 root telemetry 17504  3 nov.  11:14 /usr/local/bin/helios-last
log
tail: impossible d'ouvrir '/var/log/helios/app.log' en lecture: Permission n
on accordée
rc attendu != 0 : 1
2026-11-03T11:14:25+01:00 INFO trame 21 ok
2026-11-03T11:14:25+01:00 INFO trame 22 ok
2026-11-03T11:14:25+01:00 INFO trame 23 ok
2026-11-03T11:14:25+01:00 INFO trame 24 ok
2026-11-03T11:14:25+01:00 INFO trame 25 ok
2026-11-03T11:14:25+01:00 INFO trame 26 ok
2026-11-03T11:14:25+01:00 INFO trame 27 ok
2026-11-03T11:14:25+01:00 INFO trame 28 ok
2026-11-03T11:14:25+01:00 INFO trame 29 ok
2026-11-03T11:14:25+01:00 INFO trame 30 ok
rc attendu 0 : 0
[root@srv-core ~]#
```

julien : tail direct refusé (rc=1), helios-lastlog autorisé (rc=0)

Mission 3 – ACL POSIX

La racine est en XFS, qui gère les ACL nativement : aucune option de montage n'est nécessaire.

3.1 Accès nominatif hors du groupe

`setfacl -R -m u:audit-ext:rX` : lecture partout, et traversée (`X` majuscule) seulement sur les répertoires. Un `+` apparaît dans `ls -l`, et une entrée `mask` est créée.



user:audit-ext:r-x ajouté ; l'auditeur liste le répertoire mais ne peut rien créer (rc=1)

3.2 ACL par défaut

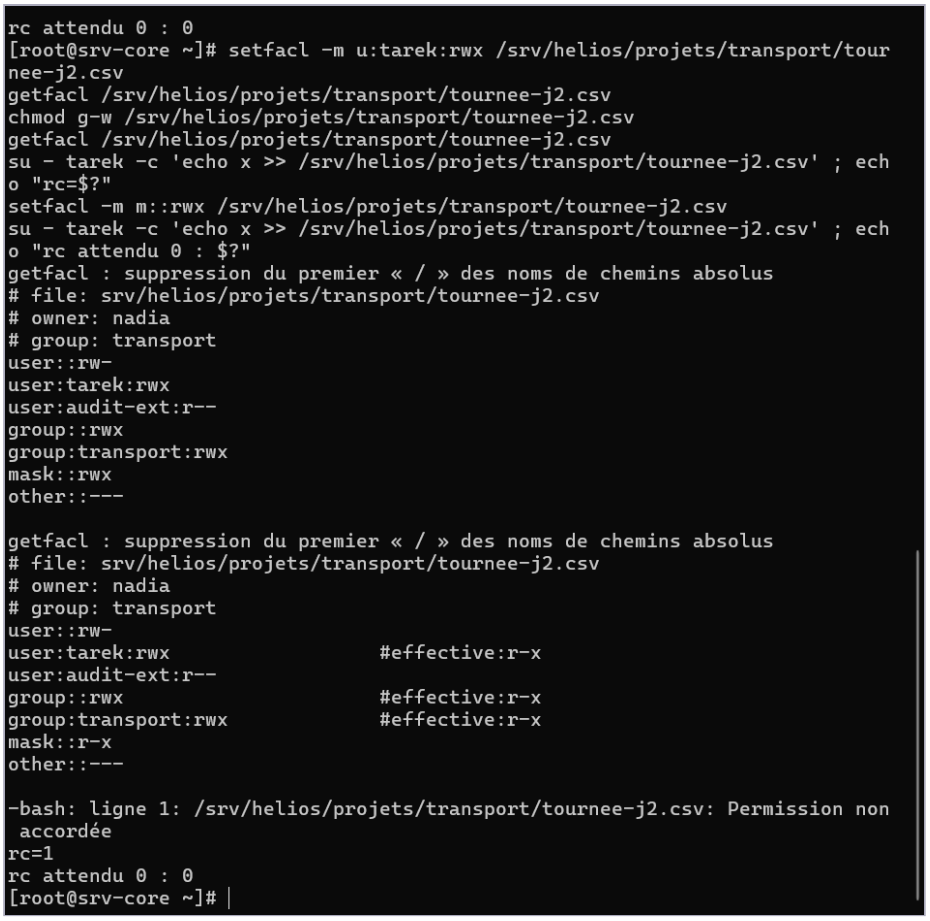
Une ACL d'accès ne s'applique qu'aux fichiers existants : `nouvelle.csv`, créé ensuite, n'a pas d'entrée audit-ext (visible dans la sauvegarde d'ACL, `configs/acl-transport-2026-11-03.txt`) et reste illisible pour l'auditeur. Les ACL par défaut (`setfacl -d`) sont recopiées sur chaque nouvel objet.



Entrées default: du répertoire ; tournee-j2.csv et semaine-41 en héritent ; lecture par l'auditeur rc=0

Le sous-répertoire `semaine-41` hérite des ACL d'accès **et** des ACL par défaut, ce qui propage la règle à toute l'arborescence future.

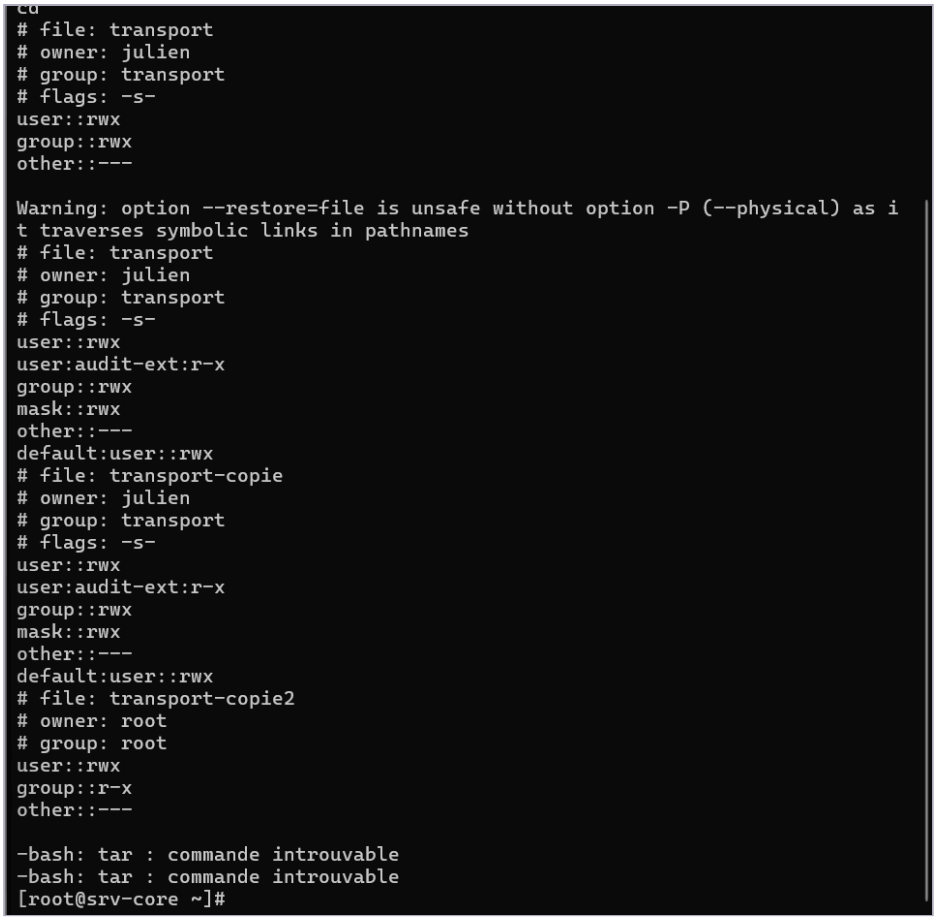
3.3 Le piège du masque effectif



Avant/après chmod g-w : mask rwx → r-x, lignes #effective:r-x ; tarek refusé (rc=1) puis rétabli (rc=0)

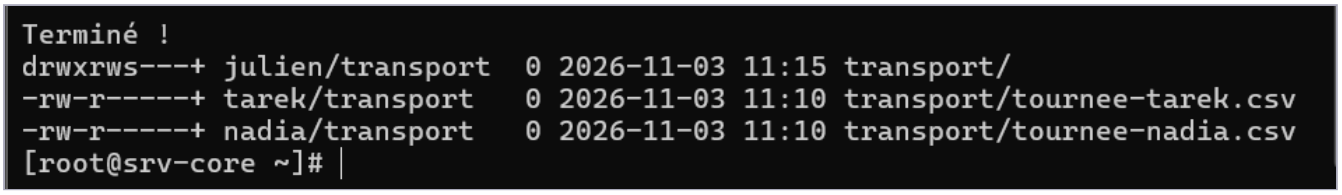
> **Ce que chmod g-w a réellement modifié :** sur un fichier doté d'ACL, les bits « groupe » de `ls -l` et de `chmod` représentent le **masque**, et non l'entrée `group::`. `chmod g-w` a donc fait passer le masque de `rwx` à `r-x`. Les entrées `user:tarek:rwx`, `group::rwx` et `group:transport:rwx` sont restées inchangées, mais leurs droits effectifs sont plafonnés à `r-x` (lignes `#effective`). Tarek perd l'écriture alors que son ACL indique toujours `rwx`. `setfacl -m m::rwx` relève le plafond.

3.4 Sauvegarder, restaurer, transporter



setfacl -b efface, --restore rétablit ; cp -a préserve, cp -r perd ACL, setgid et propriétaires

La copie `cp -r` arrive en `root:root`, sans setgid et sans ACL : une copie mal faite casse silencieusement le modèle de droits. L'avertissement de `--restore` recommande `-P` pour ne pas suivre les liens symboliques.



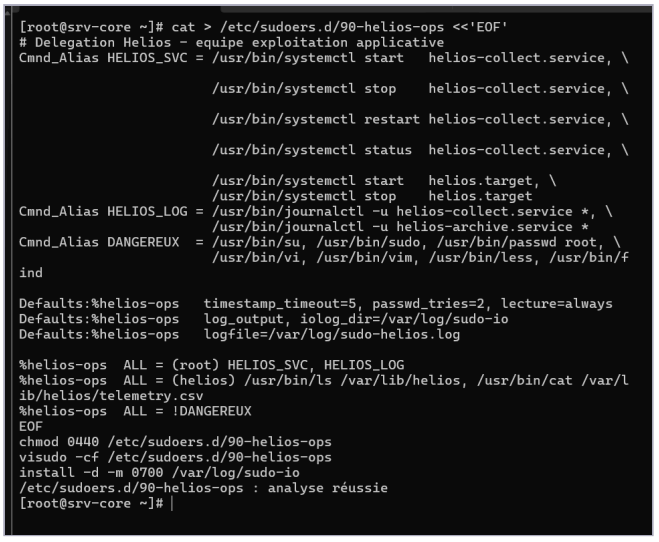
tar --acls --xattrs (tar installé au préalable) : les + et le setgid sont conservés dans l'archive

Mission 4 – Délégation sudo fine et traçable

4.1 Règle restreinte pour helios-ops

Le fichier `configs/90-helios-ops` définit :

- **HELIOS_SVC / HELIOS_LOG** : uniquement start/stop/restart/status du collecteur et de helios.target, et la lecture de leurs journaux ;
- des commandes en tant que **helios** (et non root) pour lire la télémétrie, selon le principe du moindre privilège ;
- **!DANGEREUX** : refus explicite de su, sudo, passwd root et des programmes capables d'ouvrir un shell (vi, vim, less, find) ;
- **Defaults** : ré-authentification après 5 min, 2 essais, bannière, `log_output` (enregistrement complet des sessions dans /var/log/sudo-io) et journal dédié.



visudo -cf : analyse réussie

4.2 Vérifier, tracer, rejouer

```
[root@srv-core ~]# sudo -l -U julien
Entrées Defaults correspondant pour julien sur srv-core :
    !visiblepw, always_set_home, match_group_by_gid,
    always_query_group_plugin, env_reset, env_keep="COLORS DISPLAY HOSTNAME
    HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG
    LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE LC_IDENTIFICATION
    LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY LC_NAME LC_NUMERIC
    LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS
    _XKB_CHARSET XAUTHORITY", secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin,
    timestamp_timeout=5, passwd_tries=2, lecture=always, log_output,
    iolog_dir=/var/log/sudo-io, logfile=/var/log/sudo-helios.log

L'utilisateur julien peut utiliser les commandes suivantes sur srv-core :
    (root) /usr/bin/systemctl start helios-collect.service,
        /usr/bin/systemctl stop helios-collect.service, /usr/bin/systemctl
        restart helios-collect.service, /usr/bin/systemctl status
        helios-collect.service, /usr/bin/systemctl start helios.target,
        /usr/bin/systemctl stop helios.target, /usr/bin/journalctl -u
        helios-collect.service *, /usr/bin/journalctl -u
        helios-archive.service *
    (helios) /usr/bin/ls /var/lib/helios, /usr/bin/cat
        /var/lib/helios/telemetry.csv
    (root) !/usr/bin/su, !/usr/bin/sudo, !/usr/bin/passwd root,
        !/usr/bin/vi, !/usr/bin/vim, !/usr/bin/less, !/usr/bin/find
[root@srv-core ~]#
```

sudo -l -U julien

```
[julien@srv-core ~]$ sudo systemctl restart helios-collect.service ; echo "r
c=$?"
rc=0
[julien@srv-core ~]$ sudo systemctl restart sshd
Désolé, l'utilisateur julien n'est pas autorisé à exécuter « /bin/systemctl
restart sshd » en tant que root sur srv-core.
[julien@srv-core ~]$ sudo -u helios cat /var/lib/helios/telemetry.csv | tail
 -3
2026-11-03T11:22:04+01:00,0.53,1380528
2026-11-03T11:22:10+01:00,0.49,1382576
2026-11-03T11:22:15+01:00,0.45,1382576
[julien@srv-core ~]$ sudo journalctl -u helios-collect.service -n 5
nov. 03 11:21:51 srv-core systemd[1]: Started Collecteur de telemetrie Heli>
nov. 03 11:22:03 srv-core systemd[1]: Stopping Collecteur de telemetrie Hel>
nov. 03 11:22:03 srv-core systemd[1]: helios-collect.service: Deactivated s>
nov. 03 11:22:03 srv-core systemd[1]: Stopped Collecteur de telemetrie Heli>
nov. 03 11:22:03 srv-core systemd[1]: Started Collecteur de telemetrie Heli>

[julien@srv-core ~]$ exit
déconnexion
[root@srv-core ~]# su - nadia
Dernière connexion : mardi  3 novembre 2026 à 11:19:56 CET sur pts/1
[nadia@srv-core ~]$ sudo -l

Nous espérons que vous avez reçu de votre administrateur système local
les consignes traditionnelles. Généralement, elles se concentrent sur ces tr
ois éléments :

    #1) Respectez la vie privée des autres.
    #2) Réfléchissez avant d'utiliser le clavier.
    #3) De grands pouvoirs confèrent de grandes responsabilités.

Pour des raisons de sécurité, le mot de passe que vous tapez ne sera pas vis
ible.

[sudo] Mot de passe de nadia :
Désolé, l'utilisateur nadia ne peut pas utiliser sudo sur srv-core.
[nadia@srv-core ~]$ exit
déconnexion
[root@srv-core ~]#
```

restart helios-collect autorisé (rc=0), restart sshd refusé, lecture en tant que helios, journalctl ; nadia hors groupe refusée

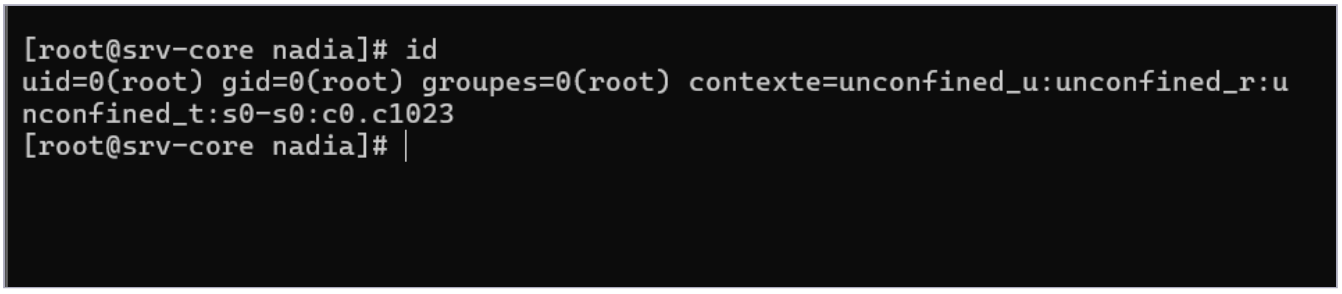
Les tests ont été faits en session interactive (`su - julien`) : avec `su - julien -c '…'`, sudo n'a pas de terminal pour demander le mot de passe.



sudoreplay -l (qui, quand, en tant que qui, quelle commande, TSID) et rejeu de la dernière session

4.3 Une règle laxiste ne protège rien

Règle volontairement fautive : `nadia ALL=(root) NOPASSWD: /usr/bin/vim /srv/helios/projets/transport/*` (vim-enhanced installé au préalable). Vim étant lancé en root, sa commande `:!` exécute n'importe quel programme en root.



Shell obtenu depuis sudo vim : uid=0(root)

Correction : la règle est remplacée par `sudoedit`. sudoedit copie le fichier dans un fichier temporaire, lance l'éditeur **avec les droits de nadia**, puis recopie le résultat avec les droits root. L'éditeur n'est jamais privilégié. `!sudoedit_checkdir` est nécessaire, car nadia peut écrire dans transport/ et sudoedit refuse sinon d'éditer dans un répertoire inscriptible.

```
[nadia@srv-core ~]$ sudo vim /srv/helios/projets/transport/tournee-nadia.csv
[nadia@srv-core ~]$ sudo vim /srv/helios/projets/transport/tournee-nadia.csv
[nadia@srv-core ~]$ sudo vim /srv/helios/projets/transport/tournee-nadia.csv
[nadia@srv-core ~]$ sudo vim /srv/helios/projets/transport/tournee-nadia.csv

[root@srv-core nadia]# id
uid=0(root) gid=0(root) groupes=0(root) contexte=unconfined_u:unconfined_r:u
nconfined_t:s0-s0:c0.c1023
[root@srv-core nadia]# exit
exit

Appuyez sur ENTRÉE ou tapez une commande pour continuer
[nadia@srv-core ~]$ exit
déconnexion
[root@srv-core ~]# rm -f /etc/sudoers.d/99-mauvais-exemple
printf '%s\n' 'Defaults:nadia !sudoedit_checkdir' 'nadia ALL=(root) sudoedit
 /srv/helios/projets/transport/*' > /etc/sudoers.d/91-nadia-edition
chmod 0440 /etc/sudoers.d/91-nadia-edition ; visudo -c
/etc/sudoers : analyse réussie
/etc/sudoers.d/90-helios-ops : analyse réussie
/etc/sudoers.d/91-nadia-edition : analyse réussie
[root@srv-core ~]# su - nadia
Dernière connexion : mardi  3 novembre 2026 à 11:28:06 CET sur pts/1
[nadia@srv-core ~]$ SUDO_EDITOR=vim sudoedit /srv/helios/projets/transport/t
ournee-nadia.csv
[sudo] Mot de passe de nadia :

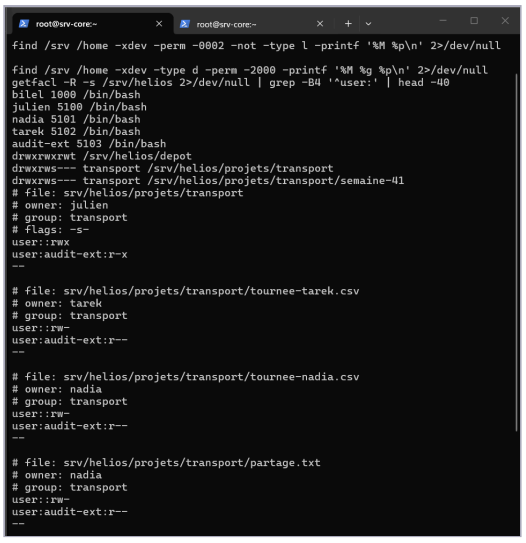
uid=5101(nadia) gid=5000(transport) groupes=5000(transport) contexte=unconfi
ned_u:unconfined_r:unconfined_t:s0-s0:c0.c1023

Appuyez sur ENTRÉE ou tapez une commande pour continuer
sudoedit: /srv/helios/projets/transport/tournee-nadia.csv unchanged
[nadia@srv-core ~]$
```

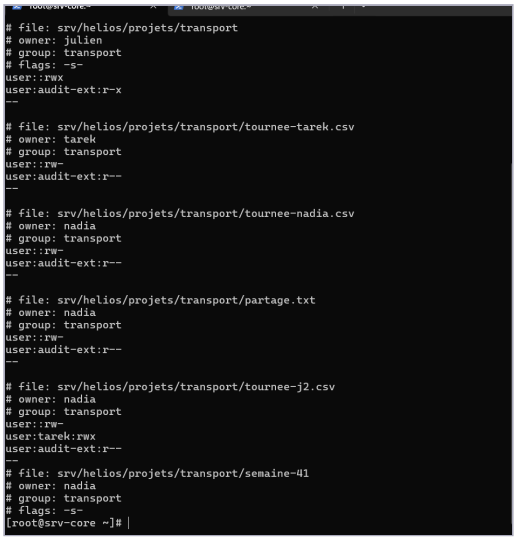
Avant : uid=0(root) – après correction : depuis sudoedit, uid=5101(nadia)

Bonus – Audit et constats

Audit en lecture seule (comptes, mots de passe vides, fichiers inscriptibles par tous, répertoires setgid, ACL nominatives, droits sudo, expiration).



Comptes humains, aucun compte sans mot de passe, world-writable, setgid, début des ACL



ACL nominatives : user:tarek:rwx résiduel sur tournee-j2.csv



Droits sudo des 4 comptes et expiration de audit-ext

#	Constat	Risque	Remédiation
1	Les 4 comptes partagent le même mot de passe initial	La compromission d'un compte expose les autres	`for u in julien nadia tarek audit-ext; do chage -d 0 "$u"; done`
2	ACL résiduelle `user:tarek:rwx` sur tournee-j2.csv (test 3.3)	Écriture non prévue par le modèle	`setfacl -x u:tarek /srv/helios/projets/transport/tournee-j2.csv`
3	sudoedit de nadia sur `transport/*` avec `!sudoedit_checkdir`	Édition en root de tout fichier du répertoire, y compris ceux d'autrui	Lister les fichiers autorisés nominativement dans 91-nadia-edition
4	`/srv/helios/depot` inscriptible par tous (1777)	Tout compte, y compris de service, peut y déposer des fichiers	`chgrp transport /srv/helios/depot && chmod 3770 /srv/helios/depot`
5	Connexion SSH root par mot de passe autorisée, mot de passe faible	Accès root direct, cible de force brute	`PermitRootLogin prohibit-password` dans sshd_config, puis `systemctl reload sshd`

Conformément à la consigne, ces remédiations n'ont pas été appliquées.

Livrables et conclusion

Fichier (configs/)	Rôle
login.defs-extrait.txt	Politique d'expiration et UMASK
50-helios.conf	Qualité des mots de passe (pwquality)
faillock.conf	Verrouillage sur échecs
helios-umask.sh	umask par groupe
helios-lastlog.c	Source du binaire setgid
acl-transport-2026-11-03.txt	Sauvegarde des ACL (getfacl -R)
90-helios-ops, 91-nadia-edition	Délégations sudo validées par visudo

Le modèle demandé est en place. L'équipe transport partage ses fichiers grâce au setgid et au umask 002. L'auditeur lit sans écrire et sans être membre du groupe, grâce aux ACL par défaut, sur un compte qui expire automatiquement. Julien pilote le collecteur via sudo, sans être root, et toutes ses sessions sont enregistrées.

Enseignements : le masque ACL peut annuler silencieusement des droits ; une copie sans `-a` détruit ACL et setgid ; autoriser un éditeur ou un pager via sudo revient à donner root, d'où `sudoedit`.

Difficultés rencontrées : aucun profil authselect présent (sélection explicite de sssd), outils absents de l'image Minimal (gcc, tar, vim-enhanced, installés), et sudo sans terminal via `su -c` (tests faits en session interactive). La capture du refus de lecture de nouvelle.csv avant la pose des ACL par défaut n'a pas été conservée ; l'absence d'entrée audit-ext sur ce fichier est visible dans la sauvegarde d'ACL.